

Vulnerability Assessment Report

Assessed by: Mlungisi Sibitane

CIN ID: FIT/JUN26/CS8990

Date: June 2026

Organization: Future Interns Cyber Security Internship Task 1

Executive Summary

A passive vulnerability assessment was conducted on the KArt Everything website (<https://karteverything.vercel.app>) to identify common security weaknesses and assess potential risks. The review included security header analysis, network exposure assessment, and passive vulnerability scanning using industry-standard tools.

The assessment identified several medium and low-risk finding, primarily related to missing security headers and client-side security controls. No critical or high-risk vulnerabilities were discovered. Additionally, positive security measures such as HTTPS enforcement and HTTP Strict Transport Security (HSTS) were observed.

Overall, the website demonstrates a reasonable security posture. Implementing the recommended improvements will further enhance protection against common web-based threats and align the application with security best practices.

Finding F-01: Missing Content Security Policy (CSP)

Risk: Medium

Description: The website does not appear to define a Content Security Policy (CSP) header.

Business Impact: A CSP helps restrict where scripts, styles, and other resources may load from. Without it, future code injection vulnerabilities could have a greater impact.

Recommendation: Implement a Content-Security-Policy header limiting resources to trusted origins.

Evidence: Header review shows no CSP header present.

Finding F-02: Missing X-Frame Options

Risk: Low

Description: The website does not appear to include click-jacking protections.

Business Impact: Attackers could potentially embed the site inside another web-page and trick users into interacting with hidden content.

Recommendation

Configure: X-Frame-Options: SAMEORIGIN

Or

Configure: X-Frame-Options: DENY

Finding F-03: Missing X-Content-Type-Options

Risk: Low

Description: The website does not define the X-Content-Type-Options header.

Business Impact: Browsers may attempt to interpret files differently than intended.

Recommendation

Configure: X-Content-Type-Options: nosniff

Finding F-04: Missing Referrer Policy

Risk: Low

Description: The website does not specify referral information should be shared with external sites.

Business Impact: Potential exposure of URL information when users follow outbound links.

Recommendation

Configure: Referrer-Policy: strict-origin-when-cross-origin

Finding F-05: Additional Service Exposure Observed

Risk: Informational

Description: A passive network scan of the target domain identified multiple accessible services. Because the website is hosted on shared cloud infrastructure, it could not be confirmed whether all detected services are directly associated with the assessed website.

Tool Used: Nmap 7.99

Command Executed:

→ Nmap -Pn karteverything.vercel.app

Output:

Port	State	Service
21/tcp	Open	ftp
80/tcp	Open	https
443/tcp	Open	https

Business Impact: Publicly accessible services increase the visible attack surface of an environment. While the presence of additional services does not necessarily indicate vulnerability, organizations should periodically review exposed services to ensure only those required for business operations are accessible.

Recommendation: Review publicly services where administrative control exists and verify that only necessary services are accessible. For cloud-hosted environments, validate exposure through the provider's security documentation and configuration settings.

ZAP by Checkmarx Scanning Report

Date: 2026-06-08

Tool Used: OWASP ZAP Passive Scan

Target URL: <https://karteverything.vercel.app/>

Finding F-01: Missing Anti-Click-jacking Protection

Risk Level: Medium

Description: The application does not implement clickjacking protection through the either X-Frame-Options header or the Content-Security-Policy frame-ancestors directive.

Business Impact: An attacker could embed the website inside a malicious page and trick users into interacting within hidden content.

Recommendation

Implement either:

X-Frame-Options: DENY

Content-Security-Policy: frame-ancestors 'none';

Finding F-02: Missing Sub-resource Integrity (SRI)

Risk Level: Medium

Description: External JavaScript resources are loaded without a Sub-resource Integrity (SRI) attribute. ZAP specifically identified an externally loaded Google Tag Manager resource

Business Impact: If a third-part CDN or external provider were compromised, malicious code could potentially be served to visitors.

Evidence:

<link rel="preload"

href="https://www.googletagmanager.com/gtag/js?id=undefined"

as="script"/>

Recommendation: Add SRI hashes to externally loaded scripts where supported.

Finding F-03: Overly Permissive CORS Policy

Risk Level: Medium

Description: ZAP detected responses containing: Access-Control-Allow-Origin: *. This was observed on resources used by the application.

Business Impact: Permissive CORS policies can allow external websites to access resources intended only for trusted origins.

Recommendation: Restrict allowed origins to trusted domains whenever possible.

Finding F-04: Missing X-Content-Type-Options Header

Risk Level: Low

Description: The X-Content-Type-Options header was not observed on application resources.

Business Impact: Browsers may attempt MIME-sniffing, potentially interpreting content differently than intended.

Recommendation: X-Content-Type-Options: nosniff

Finding F-05: Suspicious Comment Disclosure

Risk Level: Informational

Description: ZAP identified comment content containing the term "admin" within a JavaScript asset.

Business Impact: Comment and development artifacts can occasionally reveal implementation details useful to attackers.

Recommendation: Review production assets and remove unnecessary comments during the build process.

Security Strength Section

1. HTTPS enforced throughout the application.
 2. HSTS enables (max-age=6307200; includeSubDomains; preload).
 3. No high-risk vulnerabilities identified during the passive assessment.
 4. Application hosted on a modern cloud platform (Vercel).
 5. Authentication pages were not exposed during passive testing.
 6. No evidence of sensitive credentials or secrets exposed through public pages.
-

Remediation Steps

The identified security recommendations were reviewed and are technically feasible to implement within the application's Next.js configuration. Recommended controls include Content Security Policy (CSP), anti-click-jacking protection, MIME-sniffing prevention, and enhanced browser security policies. These controls can be deployed through HTTP security headers without requiring significant architectural changes.
